WorkBuddy

KD Tracker - Employee Attendance and Work Monitoring

Live Application Report

Report date	17 October 2026
Prepared for	KD Associates / KD Marketing
Web portal	https://kd-tracker-three.vercel.app
API	https://kd-tracker.onrender.com
Code version	main @ 5e40d58 (working tree clean, all changes pushed)
Scope	Architecture, features, security and privacy, QA results, live-state check, risks and recommendations

How this report was produced: the source code was read and tested (127 backend tests, 81 desktop-agent tests), the application was exercised through its API and web portal, and the live deployments were probed from the outside on the report date. Anything that could not be verified is marked **not verified**.

1. Executive summary

WorkBuddy is a working, deployed system. Employees punch in and out on a web portal, a desktop agent captures periodic screenshots and activity counts while they work, and HR and team leaders review attendance, productivity, leave and payroll. The system is live on Vercel (web), Render (API) and Neon (PostgreSQL).

Overall status

Area	Status	Comment
Web portal and API	**Working**	Sign-in, consent, and the admin pages (employees, audit log, leave) were seen working on the live site. The new Help page was not checked live.
Automated tests	**Passing**	Backend 127/127, desktop agent 81/81.
Data store	**Working**	Neon PostgreSQL with 23 migrations applied.
Screenshot and audio files	**At risk**	Stored on the API server's disk, which is wiped on every restart or redeploy (see 7.1).
Hosting plan	**Test-grade**	Free tiers: API sleeps when idle; Vercel Hobby is not licensed for commercial use.
Desktop agent	**Dev mode**	Runs from source with `npm start`. No installer has been built or distributed yet.
Security headers (web)	**Open**	The Vercel site sends no CSP / X-Frame-Options / nosniff headers.

The five things to do first

- **Move screenshots and audio to persistent storage** (Cloudflare R2 or S3). Until then captured media is lost on every redeploy.
- **Rotate credentials that were exposed during setup**: a session cookie (including a refresh token) was pasted into a chat. Sign out everywhere or reset the admin password, and confirm the demo accounts do not exist in the live database.
- **Choose real hosting before real employees use it**: an always-on API plan, and a Vercel plan (or another host) that allows commercial use.
- **Build and distribute the desktop agent installer** pointing at the live API.
- **Add security headers to the web portal** and fix the API's CORS configuration (see 6).

2. Live environment

Layer	Technology	Where it runs	Notes
Web portal	Next.js 15, React 19	Vercel (Hobby plan)	https://kd-tracker-three.vercel.app. Deploys automatically on every push to `main`.
API	Node.js, Express, Knex	Render (free web service)	https://kd-tracker.onrender.com. Sleeps after about 15 minutes idle; first request can take 30-60 s.
Database	PostgreSQL	Neon	Free tier. Migrations run on every API start.
Media files	Local disk (`STORAGE_DRIVER=local`)	Render instance disk	Ephemeral. The S3-compatible driver exists in the code but is not enabled.
Desktop agent	Electron, sql.js, uiohook, active-win	Employee computers	Talks to the API directly. Offline queue in a local SQLite file.
Source control	Git / GitHub	mediakdmarketing-sys/kd-tracker	Branch `main`; Vercel and Render both deploy from it.

Request flow

- **Browser to web portal.** The portal keeps the sign-in tokens in httpOnly cookies, so page scripts can never read them.
- **Web portal to API.** Pages and a small proxy (`/bff`) call the API from the server and attach the access token. The API's address is never sent to the browser.
- **Desktop agent to API.** The agent signs in, asks the server what the employee's state is, and uploads screenshots, audio and activity counts. Uploads are queued and retried when the connection drops.
- **Background jobs** run inside the API process on a schedule: closing abandoned shifts (hourly), purging expired media (02:15 daily) and generating payroll (3 AM on the 1st of each month). They only run while the API is awake, which matters on a sleeping free plan.

Configuration (names only)

API: NODE_ENV, DB_CLIENT, DATABASE_URL, JWT_SECRET, JWT_REFRESH_SECRET, CORS_ORIGINS (and optionally STORAGE_DRIVER with the S3_* settings). Web: API_BASE_URL, COOKIE_SECURE. Agent: KD_API_URL or `settings.json` (apiBaseUrl). Values are kept in the hosting dashboards and are not recorded here.

3. Features by role

Role	What they can do
Employee	Punch in, start/end break, punch out. See own history. Request leave (sick, bereavement, personal, emergency, company vacation; full or half day; proof upload required for sick, bereavement and emergency). Optional project picker when projects exist. Read the in-app Help page.
Team leader	Everything an employee can do, plus: see the departments they lead, a live board of their team, each member's attendance, screenshots, audio samples and activity, and approve or reject the team's leave requests.
Admin / HR	Everything above for the whole company, plus: add, edit, deactivate employees and reset passwords; blur an employee's screenshots; assign leaders; departments and projects; company live board; productivity scores; reports with CSV export; monthly payroll with CSV export; all leave requests; the audit log; global settings.

Desktop agent

- Takes screenshots of every display at random intervals (5-10 minutes by default) only while the employee is punched in, not on a break, and has accepted the monitoring notice.
- Counts keystrokes and mouse actions and records the active application name; it never stores what is typed.
- Optional audio samples (5 minutes of recording, then an 8 minute gap) only if the employee opted in.
- Signs in automatically when the employee signs in on the web portal (after a Connect confirmation) and shows notifications when a shift is changed from the portal.
- Keeps an offline queue so nothing is lost if the connection drops.

Admin settings (apply to everyone, no agent reinstall)

Screenshot interval, audio sample length and gap, target shift length (9 h), break allowance (60 min), idle threshold (10 min), auto-close of abandoned shifts (16 h), media retention (31 days), and whether idle time is deducted from payroll.

Built-in help

A role-aware **Help** page (left menu) explains each role's tasks. A separate full User Guide is in `docs/USER_GUIDE.md`.

4. Security and privacy design

Control	How it works
Consent first	No punch-in until the monitoring notice is accepted. Audio consent is separate and optional; HR cannot grant it on an employee's behalf.
Role-based access	The API refuses admin, payroll and leader routes to other roles (403). The portal redirects employees away from admin pages.
Sessions	Short-lived access token plus a rotating refresh token. Reuse of an old refresh token outside a 2 minute grace window signs the employee out everywhere.
Cookies	HttpOnly session cookies; Secure flag controlled by COOKIE_SECURE (set to 1 in production).
Login protection	Rate limiting per IP and email; the same error message for wrong email and wrong password; the deactivated-account message is distinct.
Audit log	Every admin view of screenshots, audio or attendance history is recorded with the admin's name, the employee and the time. It is append-only.
Retention	Screenshot and audio files are deleted after 31 days by default; the record that a capture happened is kept.

Control	How it works
Desktop agent hand-off	Web sign-in can sign the agent in using a one-time, 60 second code stored only as a hash. A signed-out agent now asks the person to confirm before accepting a link, so a web page cannot silently attach the computer to someone else's account.
Input handling	Malformed JSON, missing fields and out-of-range paging values are rejected with 400. CSV exports neutralise spreadsheet formula injection.
Single open shift	A database rule guarantees one open shift per employee even under concurrent requests.

5. Quality assurance results

Automated tests

Suite	Before fixes	Now
Backend (API, jobs, retention, payroll, leave, agent connect)	126 of 127 passing	**127 of 127 passing**
Desktop agent (queue, uploader, scheduler, capture, connect link)	80 of 81 passing	**81 of 81 passing**

Defects found and fixed

ID	Severity	Problem	Fix
BUG-1	High	A wrong password reloaded the sign-in page and never showed an error.	The sign-in call no longer triggers the session-expired redirect. Verified live.
BUG-2	High	A punch-out racing the stale-shift sweeper could overwrite an auto-closed shift, leaving a contradictory record.	The punch-out update now only applies to a still-open shift; the loser gets a 409.
BUG-3	Medium	Opening a non-existent employee page returned a 500.	Now a normal 404 page.
BUG-4	Medium	A desktop-agent test failed (4 items queued instead of 2).	Test corrected; production behaviour was already right.
BUG-5	Low	Malformed JSON to the web login route returned 500.	Now a 400.
SEC-1	High	A signed-out agent accepted any connect link, so a web page could attach it to an attacker's account.	The agent now asks for confirmation (Connect / Cancel) first.
PROD-1	High	Truncated JSON in the browser (Unterminated string / Expected ':' errors) on the live site. The CDN in front of the API compresses replies and leaves a content-length for the compressed size, which the web proxy copied.	Web-to-API requests ask for uncompressed replies, the proxy sets content-length from the real body, and the client reloads the page if a reply is ever cut short.
PROD-2	Medium	Vercel builds intermittently failed downloading Google Fonts.	Fonts are now bundled from npm packages; no build-time download.
PROD-3	Medium	The desktop agent defaulted to http://localhost:4000, so it never reached the cloud.	Set apiBaseUrl in the agent's settings file (or KD_API_URL).

Still open

ID	Severity	Item
OPEN-1	Medium	Web portal sends no security headers (CSP, X-Frame-Options, nosniff, Referrer-Policy). The API does (helmet).
OPEN-2	Medium	Agent connect rate limit is 30 requests per 15 minutes per IP. An office behind one network address could hit it at the start of a shift.

ID	Severity	Item
OPEN-3	Low	The audit log records private 10.x addresses instead of the employee's real IP, because the API sees several proxy hops in front of it.
OPEN-4	Low	The agent-code endpoint has only the general rate limit; a signed-in user could create many short-lived rows.
OPEN-5	Low	If an agent is already signed in as one person and someone else signs in to the portal on the same computer, the agent keeps monitoring the first person without telling the second.
OPEN-6	Low	A browser preflight (OPTIONS) request from the web origin to the API returns 500 on the live API. It does not affect the portal (which calls the API from the server) but indicates CORS_ORIGINS does not match the live web address.

Not covered by testing: the Electron agent's native screen capture on a real desktop session, the connect confirmation dialog in a live agent, mobile layouts, load and performance, backup and restore, and the PostgreSQL migration path under load.

6. Live-state check (17 October 2026)

Probes sent to the public addresses using fake credentials only.

Check	Result	Meaning
Web /login	200 OK, Strict-Transport-Security present	Site is up and forces HTTPS.
Web /admin without a session	307 redirect to /login?next=/admin	Access control works.
Web security headers	No CSP, X-Frame-Options, nosniff or Referrer-Policy	OPEN-1.
API responds	404 JSON for an unknown GET (server awake)	API is up behind Cloudflare.
API security headers	CSP, nosniff, SAMEORIGIN, no-referrer, HSTS present	helmet is active.
API login with a fake account	401 with a complete JSON body	Error path is clean.
API CORS preflight from the web origin	500 Internal Server Error	OPEN-6; configuration should be corrected.
Git state	Clean; HEAD 5e40d58 equals the remote	Everything tested is what is deployed (Vercel deployment status not verified).

7. Risks and limitations

7.1 Media files are not persistent (highest risk)

Screenshots and audio are written to the API server's local disk. On Render's free plan that disk is erased on every deploy, restart or spin-down. The database would still say a screenshot exists, but the image would be gone and the portal would show a broken image. Fix: set STORAGE_DRIVER=s3 with Cloudflare R2 (10 GB free) or any S3-compatible bucket. The driver already exists; this is configuration, not a rewrite. Existing local files are not migrated automatically.

7.2 Free hosting behaviour

- The API sleeps when idle. The first request after a quiet period is slow, uploads from the agent are delayed, and the scheduled jobs (close stale shifts, purge, payroll) do not run while it sleeps.
- Vercel's Hobby plan is for personal, non-commercial projects. A company deployment should use a paid plan or another host.
- Neon's free tier has small storage and compute limits. Demo seed data alone is about 17,000 rows; real capture metadata grows with every employee.

7.3 Credential hygiene

- A browser session cookie, including a long-lived refresh token, was pasted into a chat during troubleshooting. Treat it as exposed: sign out of the portal and reset the admin password (`db:create-admin` with ADMIN_RESET=1 revokes all sessions).
- Demo accounts (priya.raman@..., karthik.s@... with the published demo password) must not exist in the live database. Check the Employees list and deactivate or delete any that do.
- Database and JWT secrets live only in the hosting dashboards. Do not paste them into chats or commit them.

7.4 Other

- The desktop agent has only been run from source. A signed installer is needed for normal employees (`npm run build:win` in desktop-agent).
- Monitoring consent can only be withdrawn through HR by design; make sure a process exists for that.
- Employee monitoring is regulated in many places. The consent notice, 31 day retention and audit log are good foundations, but legal review for your jurisdiction is advisable.

8. Recommended roadmap

Priority	Action	Effort
P0 - now	Enable persistent media storage (R2 or S3) and test an upload that survives a redeploy.	1-2 hours
P0 - now	Sign out everywhere / reset the admin password; confirm no demo accounts in the live database.	15 minutes
P1 - before go-live	Move the API to an always-on plan (or a small VPS) and the web to a commercially licensed plan or host.	Half a day
P1 - before go-live	Build the Windows installer for the desktop agent with the live API URL baked in; test on a clean machine.	Half a day
P1 - before go-live	Add security headers to the web portal (next.config headers: CSP, X-Frame-Options, nosniff, Referrer-Policy).	1-2 hours
P1 - before go-live	Set CORS_ORIGINS on Render to the live web address and make a disallowed origin return a clean 403 instead of 500.	30 minutes
P2	Record the real client IP in the audit log (adjust trusted proxy depth).	1 hour
P2	Key the agent-connect rate limit per code or employee rather than per IP; add a per-user limit to agent-code.	1-2 hours
P2	Uptime monitoring (a ping every 5 minutes) and database backups on a paid plan.	1 hour
P2	Tell the second user when the agent is already signed in as someone else (OPEN-5).	Half a day
P3	Tamil version of the user guide and help page; PDF export of reports.	As needed

Suggested rollout

- Week 1: fix P0 and P1, then a pilot with 3-5 volunteers (one leader, one admin) on the real deployment.
- Week 2: review pilot feedback and the audit log, fix issues, then roll out department by department.
- Ongoing: weekly review of flagged shifts before each payroll run; monthly check of retention and storage usage.

Appendix A - Operating cheat sheet

Task	How
Deploy a change	Commit and push to main. Vercel (web) and Render (API) redeploy automatically. Check the top deployment in Vercel is Ready and Current.
Create the first admin	In the backend folder with the live DATABASE_URL set: set ADMIN_NAME, ADMIN_EMAIL, ADMIN_PASSWORD (12+ characters), run `npm run db:create-admin`, then clear the variables.
Reset an admin password	Same, plus ADMIN_RESET=1 (name not needed). All of that person's sessions are signed out.
Apply database changes	Automatic on every API start (`npm run db:migrate`). Never run db:reset on the live database; it erases everything.
Point an agent at the live API	Create %APPDATA%\kd-tracker-agent\settings.json containing {"apiBaseUrl": "https://kd-tracker.onrender.com"}, or set KD_API_URL before starting. Restart the agent.
Run everything locally	Backend: `npm run dev` in backend (port 4000; use a throwaway SQLite file, not the live database). Web: `npm run dev` in web (port 3000).
Run the tests	`npm test` in backend and in desktop-agent.
Demo logins (local data only)	priya.raman@kdmarketing.in (admin), karthik.s@kdmarketing.in (employee). Not for production.

Appendix B - Related documents

- `QA_BUG_REPORT.md` - the detailed QA findings and retest table.
- `docs/USER_GUIDE.md` - guide for employees, leaders and admins.
- `docs/DEPLOYMENT.md` and `docs/DEPLOYMENT-FREE.md` - deployment notes.
- `docs/PRODUCTION_READINESS.md` - readiness checklist from the project.